

ThreatIQ – Product Requirements Document

Agentic AI Cyber Incident Investigation & Response Platform

From Suspicion to Action

Document Control

Document Title	ThreatIQ Product Requirements Document
Version	v1.0
Status	Final – Hackathon Submission
Date	2026-09-12
Classification	Internal / Submission Ready

Table of Contents

1. Executive Summary.....	12. Potential Compromise Vectors.....
2. Problem & Security Gap Analysis.....	13. Personalized Defensive Response Engine.....
3. Target Users & Pain Point Matrix.....	14. Structured Incident Report Specification.....
4. Product Vision & End-to-End Architecture.....	15. User Experience & Demo Scenario.....
5. Core Product Workflow Details.....	16. Evaluation Framework & Success Metrics.....
6. Agentic AI Architecture & Multi-Agent System.....	17. Product Scope & Non-Goals.....
7. Orchestrator Logic & Shared Incident State.....	18. Security, Responsible AI & Product Governance.....
8. Evidence Extraction & Threat Categorization.....	19. Team Roles & Responsibilities.....
9. Threat Intelligence & RAG Architecture.....	20. Development Timeline.....
10. Evidence Correlation & Incident Relationship Map.....	21. Strategic Differentiation & Conclusion.....
11. Adaptive Cyber Interview & Dynamic Risk Reassessment.....	22. References.....
	23. Glossary.....

1. Executive Summary

ThreatIQ is an enterprise-grade, Agentic AI-powered cyber incident triage and investigation platform. It is engineered specifically for non-technical individuals, corporate employees, and small business operators who encounter suspicious digital activity but lack specialized security operations capabilities.

Central Strategic Vision

"Detection is not enough." Traditional security mechanisms tell a user if an artifact is clean or malicious. ThreatIQ bridges the critical operational gap between initial detection, complete investigation, context-aware risk assessment, and immediate defensive containment.

The Existing Problem

Today, when a user encounters a suspicious email, URL, SMS, or file, they ask a single question: *"Is this dangerous?"*

Conventional security tools return binary verdicts (Safe / Suspicious / Phishing). However, the real operational problem begins after that verdict:

- What specific elements make this suspicious?
- Are multiple separate items part of one attack?
- What information was exposed if I already clicked?
- What exact technical actions must I take right now?

The ThreatIQ Solution

ThreatIQ transforms static, isolated threat detection into an interactive, multi-agent cyber incident investigation.

By deploying 8 core specialized autonomous AI agents — supplemented by adaptive interview and impact analysis modules — ThreatIQ performs comprehensive indicator extraction, threat intelligence correlation, adaptive questioning, dynamic risk scoring, and automated report generation.

Core Platform Workflow Architecture

EVIDENCE → INVESTIGATE → CORRELATE → ASSESS → ASK → REASSESS → RESPOND → REPORT

2. Problem & Security Gap Analysis

The fundamental cybersecurity threat facing modern organizations and individuals is not merely the volume of phishing or scams, but the velocity gap: people encounter potential cyber threats faster than they can evaluate, comprehend, and defend against them.

The Critical Incident Timeline Gap

Consider a standard real-world corporate spear-phishing incident:

Time	Event
10:02 AM	Employee receives urgent email regarding "Office365 Password Expiration".
10:04 AM	Employee clicks embedded link (auth-login-update.com).
10:05 AM	Employee inputs corporate username and password.
10:06 AM	Employee realizes the page glitched and feels suspicious.
10:07 AM	CRITICAL GAP: Existing tool says "This link is Phishing". The employee asks: "I already entered my password... what do I do RIGHT NOW?"

Simply flagging "This is phishing" provides zero defensive value after credentials have been submitted. The user urgently requires active incident triage, impact quantification, and step-by-step remediation guidance.

3. Target Users & Pain Point Matrix

1. Non-Technical Individuals

Daily consumers receiving SMS scams, WhatsApp fraud, fake banking alerts, and impersonation attempts.

Core Need: Clear, plain-language guidance without complex technical jargon.

2. Corporate Employees

Staff members who act as the primary attack surface for corporate spear-phishing and credential harvesting.

Core Need: Instant initial triage layer before escalating false alarms to IT/SOC teams.

3. Small Businesses (SMBs)

Organizations lacking a dedicated 24/7 Security Operations Center (SOC) or in-house cyber analysts.

Core Need: Lightweight, autonomous first-response security assistant and reporting tool.

Comprehensive User Pain Point Mapping

Pain Point	Identification	Real-World User Manifestation	ThreatIQ Platform Mitigation
P1	Absolute Uncertainty	"I don't know whether this message from my bank is authentic or a scam."	Multi-agent threat analysis categorizes the threat and explicitly explains supporting indicators.
P2	Lack of Technical Investigation	"I don't know how to inspect raw email headers, domain registration, or redirects."	Investigation Agent queries VirusTotal, RDAP, and WHOIS APIs automatically in the background.
P3	Lack of Interaction Context	"I clicked the link 5 minutes ago. Does that change my security risk?"	Adaptive Interview module asks follow-up questions and dynamically recalculates risk from HIGH to CRITICAL.
P4	Vague / Generic Advice	"Security tools just tell me to 'Be careful online'—what do I actually click now?"	Personalized Response Engine generates a step-by-step containment playbook tailored to exact actions.
P5	Fragmented Evidence	User has a screenshot of an SMS, a URL, and a phone number as separate items.	Correlation Agent links all multi-modal artifacts into a single unified Incident Case.

4. Product Vision & End-to-End Architecture

North Star Specification

"When a non-technical user encounters a suspicious digital incident, ThreatIQ turns uncertainty into an evidence-based understanding of the situation and provides a clear, prioritized path to safer defensive action."

ThreatIQ operates as an AI first-response security layer. Rather than functioning as a standard "chat prompt", it establishes an interactive security investigation environment.

1. Multi-Modal Inputs

- Screenshots (OCR & Vision)
- Raw Email Content & Headers

- SMS / WhatsApp Text
- Suspicious URLs & Domains
- User Interaction Context

2. Agentic Processing

- Indicator Extraction (IOCs)
- Threat Classification
- Threat Intel Lookup (VT/RDAP)
- Adaptive User Interrogation
- Dynamic Risk Reassessment

3. Structured Outputs

- Threat Classification Verdict
- Dynamic Risk Score (0–100)
- Impact Analysis Breakdown
- Personalized Playbook
- Executive Incident Report

5. Core Product Workflow Details

Detailed 8-Stage Triage & Investigation Sequence

1. **EVIDENCE INTAKE:** User submits screenshot, text message, email body, or malicious URL into the intake portal.
2. **INVESTIGATE:** Autonomous Extraction & Investigation Agents parse payload, identifying URLs, domains, IPs, and brand assets.
3. **CORRELATE:** Correlation Agent connects isolated indicators into a graph representation showing relationships between sender, link, and payload.
4. **ASSESS:** Risk Agent computes initial baseline threat classification and risk score based purely on incoming artifacts.
5. **ASK (ADAPTIVE INTERVIEW):** Adaptive Interview module dynamically formulates targeted follow-up questions based on extracted risk factors.
6. **REASSESS:** As user provides interaction details (e.g., "I entered my password"), Risk Agent dynamically elevates threat scoring.
7. **RESPOND:** Response Agent synthesizes grounded RAG security knowledge to generate a prioritized containment playbook.
8. **REPORT:** Report Agent formats full investigation timeline and artifacts into an executive PDF/JSON incident summary.

6. Agentic AI Architecture & Multi-Agent System

ThreatIQ rejects the monolithic LLM prompt paradigm in favor of a specialized multi-agent architecture. Each agent operates with specific tool access, system prompts, and strict boundary responsibilities, coordinated by a central Orchestrator.

Core Agent Roster & Operational Matrix

#	Agent Module	Primary Responsibility	Input Dependency	Key Technical Execution
1	Intake Agent	Ingests & normalizes incoming raw artifacts.	User Submission	Format classification (OCR image, raw text, header parse).

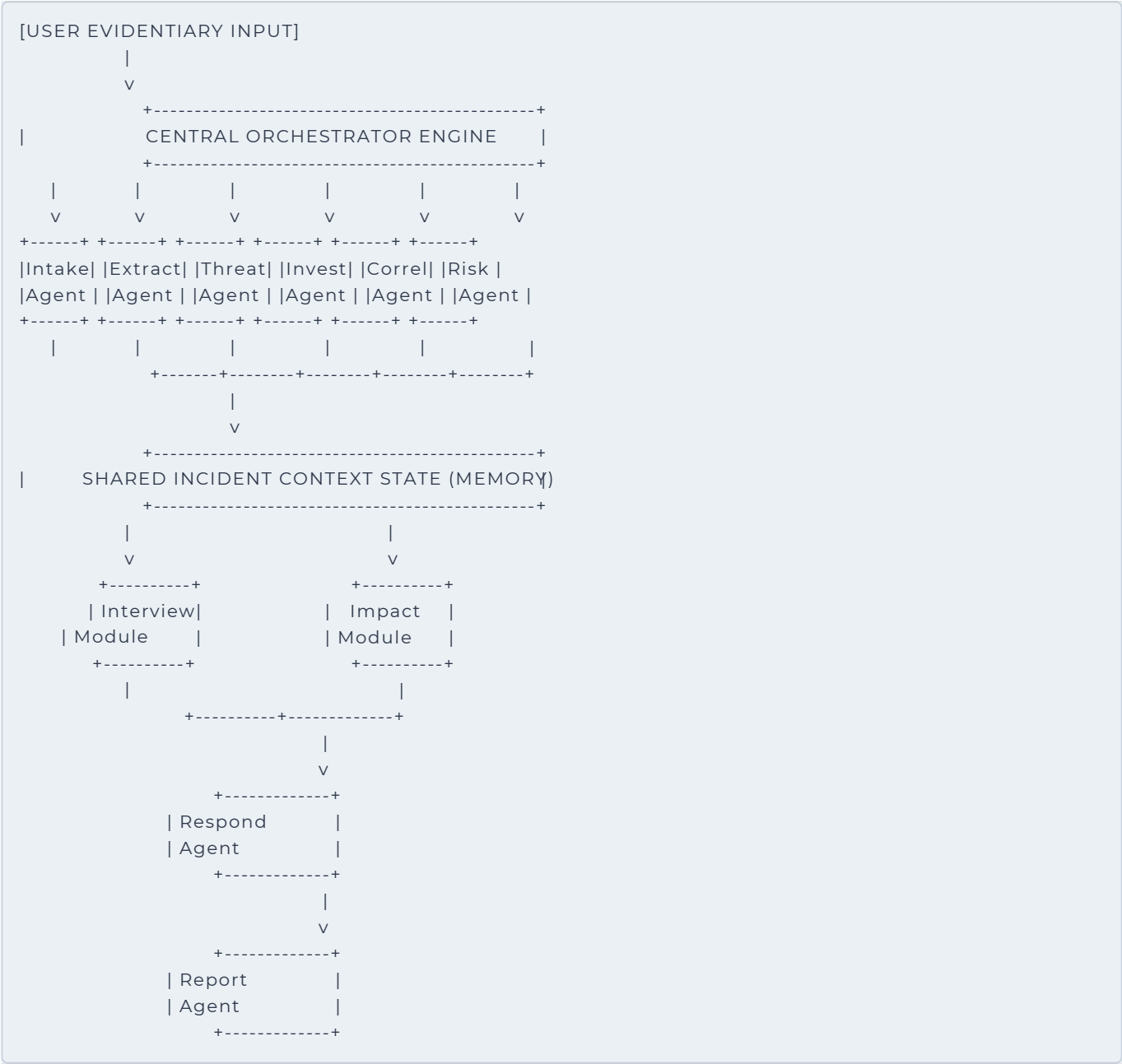
#	Agent Module	Primary Responsibility	Input Dependency	Key Technical Execution
2	Extraction Agent	Extracts actionable Security Indicators (IOCs).	Normalized Data	Regex + LLM token extraction for URLs, domains, emails, IPs.
3	Threat Analysis Agent	Categorizes threat behavior and vector type.	Extracted IOCs	Pattern match vs phishing, scam, typosquatting, fraud rules.
4	Investigation Agent	Queries external Threat Intel services.	Domain / URL / IP	API calls to VirusTotal, WHOIS/RDAP, reputation lookup.
5	Correlation Agent	Links multiple distinct artifacts together.	All Extracted IOCs	Constructs Incident Relationship Map connecting brand + domain + text.
6	Risk Agent	Calculates dynamic incident severity score.	Threat Intel + Context	Executes scoring heuristic (0–100 scale: Low, Med, High, Critical).
7	Response Agent	Generates prioritized defensive playbook.	Impact + RAG Store	Queries CISA/OWASP knowledge base for containment steps.
8	Report Agent	Compiles executive incident documentation.	Shared Context	Generates structured JSON and formatted printable report.

Supplementary Modules (Embedded within Risk & Response Agents)

Adaptive Interview Module: Formulates adaptive user interrogation. Input: Current Risk State. Execution: Generates targeted binary/multiple-choice questions.

Impact Analysis Module: Identifies potential organizational exposure. Input: User Responses. Execution: Maps interactions to credential theft, BEC, or malware exposure.

Multi-Agent Orchestration Flow



7. Orchestrator Logic & Shared Incident State

The Central Orchestrator maintains operational control over the multi-agent pipeline. It manages execution flow, prevents agent loop deadlocks, and updates a single source of truth: the Shared Incident State object.

Shared Incident State Data Schema (Python / JSON Spec)

```
{
  "incident_id": "TQ-001",
  "timestamp": "2026-09-12T14:22:00Z",
  "status": "INVESTIGATING",
  "raw_evidence": {
    "text_body": "Urgent: Your account is locked. Click http://auth-login-update.com",
    "screenshot_ocr": "Account Security Alert - Action Required",
    "sender_address": "security@alert-service-domain.com"
  },
  "extracted_indicators": {
    "urls": ["http://auth-login-update.com"],
    "domains": ["auth-login-update.com"],
    "emails": ["security@alert-service-domain.com"],
    "impersonated_brand": "Microsoft 365"
  },
  "threat_analysis": {
    "category": "Credential Phishing",
    "confidence": 0.94,
    "indicators_matched": ["Urgency", "Brand Impersonation", "Suspicious TLD"]
  },
  "threat_intelligence": {
    "virustotal_malicious_count": 14,
    "domain_age_days": 3,
    "reputation_flag": "HIGH_RISK_NEW_DOMAIN"
  },
  "user_interaction_context": {
    "link_clicked": true,
    "credentials_entered": true,
    "password_reused": true
  },
  "dynamic_risk": {
    "initial_score": 62,
    "current_score": 100,
    "severity_level": "CRITICAL"
  },
  "recommended_playbook": [
    { "priority": 1, "action": "Reset primary compromised credential immediately." },
    { "priority": 2, "action": "Revoke active OAuth sessions and reset reused logins." }
  ]
}
```

8. Evidence Extraction & Threat Categorization

ThreatIQ extracts actionable indicators from unstructured multi-modal inputs and maps them into standardized threat taxonomy categories.

Target Extracted Indicators (IOCs)

- **Network Indicators:** Malicious URLs, bare IP addresses, newly registered domains, shortened links.
- **Identity Indicators:** Sender emails, phone numbers, WhatsApp IDs, display name spoofing.
- **Content Indicators:** Urgency keywords ("Immediate Action Required"), payment demands, gift card requests.
- **Brand Assets:** Impersonated corporate logos, brand names, spoofed login forms.

Threat Taxonomy Categories

Categor y	D escription
CREDENTIAL PHISHING	Fake login portals.
FINANCIAL SCAM	Wire transfer / gift card fraud.
SOCIAL ENGINEERING	Impersonation / CEO fraud.
BRAND IMPERSONATION	Spoofed corporate identity.
ACCOUNT TAKEOVER ATTEMPT	Session hijacking.
BENIGN / SAFE	Authentic corporate comms.

Responsible AI Governance Boundary

CRUCIAL SAFETY PRINCIPLE: AI assessment is not absolute proof of compromise. ThreatIQ explicitly tags all initial findings as potential/probable threat categories until user interactions or authoritative threat intelligence confirms active exploitation.

9. Threat Intelligence & RAG Architecture

ThreatIQ combines real-time external threat intelligence lookup with grounded Retrieval-Augmented Generation (RAG) backed by authoritative cybersecurity frameworks.

Dual Intelligence Engine Topology

Layer A: Threat Intelligence Integration

Performs real-time active technical lookups across external reputation databases:

- **VirusTotal API:** Multi-engine AV scan & domain reputation.
- **RDAP / WHOIS:** Domain registration age & registrar records.
- **Google Safe Browsing:** Malicious URL classification.

Layer B: RAG Security Knowledge Base

Retrieves grounded mitigation playbooks from trusted cybersecurity repositories:

- **CISA Guidance:** Emergency incident response workflows.
- **OWASP Guides:** Credential management & web safety.
- **NIST SP 800-61:** Computer security incident handling.

10. Evidence Correlation & Incident Relationship Map

Instead of evaluating isolated artifacts individually, ThreatIQ correlates disparate evidentiary items into a unified attack graph representation.

The Correlation Agent constructs an Incident Relationship Map connecting:

- Sender identity (email address, display name, phone number)
- Brand asset (impersonated logo, corporate name)
- Network indicator (URL, domain, IP)
- Content indicator (urgency phrases, payment demands)

This graph becomes the backbone of the Executive Incident Report and the Personalized Defensive Response.

11. Adaptive Cyber Interview & Dynamic Risk Reassessment

ThreatIQ features an active feedback loop. The system dynamically updates incident risk scores based on user interaction responses.

Risk Scoring Heuristic

Factor	Score Contribution
Suspicious URL present	+20
Credential request detected	+20
Brand impersonation detected	+15
Urgency language detected	+10
Payment request detected	+20
External warning / report	+25
User clicked link	+15
User entered credentials	+15
Password reuse confirmed	+8
Maximum cap	100

Dynamic Risk Progression Trajectory

Investigation State	Triggering Event / Evidence Provided	Computed Risk Score	Assigned Severity Level
Baseline Ingestion	Initial upload of suspicious SMS with shortened URL	62 / 100	HIGH RISK
Adaptive Question 1	User answers: "Yes, I clicked the embedded link."	77 / 100	HIGH RISK
Adaptive Question 2	User answers: "Yes, I entered my login password."	92 / 100	CRITICAL RISK
Adaptive Question 3	User answers: "Yes, I use this password for personal email too."	100 / 100 (capped)	CRITICAL RISK

Severity Level Thresholds

Score Range	Severity Level
0–29	LOW
30–59	MEDIUM
60–79	HIGH
80–100	CRITICAL

12. Potential Compromise Vectors

- **Credential Exposure:** Corporate & personal password theft.
- **Financial Account Loss:** Unauthorized banking transfers or gift card draining.
- **Business Email Compromise (BEC):** Internal spearphishing from user account.
- **Identity Theft:** SSN, PII, or document compromise.

Communicated Warning Standards

ThreatIQ enforces exact responsible framing:

- **APPROVED:** "Potential credential exposure detected based on entered information."
- **PROHIBITED:** "Your bank account has been hacked."

13. Personalized Defensive Response Engine

Prioritized Containment Playbook Layout

IMMEDIATE ACTIONS (0–15 MINUTES)

1. Immediately reset the password for the affected portal ('Office365 / Corporate SSO').
2. Change the password across all secondary services where this credential pair was reused.
3. Terminate all active web sessions across account settings.

NEXT STEPS (15–60 MINUTES)

1. Enable Multi-Factor Authentication (MFA) using an Authenticator App (avoid SMS-MFA).
2. Notify corporate IT / Security Operations Team with the ThreatIQ Incident Report.

MONITORING STEPS (24–48 HOURS)

1. Monitor financial statements and email inbox forwarding rules for unauthorized changes.

14. Structured Incident Report Specification

ThreatIQ Executive Incident Report — #TQ-001

Incident Severity	CRITICAL (92/100)
Threat Category	Credential Phishing / Brand Impersonation
Target Brand	Microsoft 365
Analysis Date	2026-09-12 14:22 UTC
Orchestrator Version	v1.0-agentic
Evidence Items	2 (Screenshot + URL)

Extracted Indicators of Compromise (IOCs)

- **URL:** <http://auth-login-update.com/verify> (Malicious — VirusTotal 14/90)
- **Domain Registration:** Created 3 days ago via NameCheap (High Risk)
- **Impersonated Entity:** Microsoft Corporation

Confirmed Impact & Next Steps

User confirmed credential entry into unauthenticated third-party portal. Immediate password revocation required.

15. User Experience & Demo Scenario

The primary hackathon demonstration follows a high-impact real-world incident execution designed to immediately showcase agentic autonomy over static UI analyzers.

The "WOW" Demonstration Narrative Script

Step	Action	Expected Output
1	INTAKE: Presenter uploads screenshot of an urgent executive email stating "Corporate Email Account Suspension in 15 Minutes".	Intake Agent normalizes artifact.
2	EXTRACTION: Agents extract URL http://update-corp-sso.com and flag high-urgency keywords.	IOCs identified: URL, urgency terms, impersonated brand.
3	THREAT INTEL: Investigation Agent checks domain age (Registered 2 hours ago) and queries threat feeds.	Domain flagged as HIGH_RISK_NEW_DOMAIN.
4	CORRELATION: System links email sender, fake domain, and corporate logo into a single unified threat story.	Incident Relationship Map displayed.
5	ADAPTIVE INTERVIEW: AI asks: "Did you click this link?" → Presenter selects YES.	Risk score rises from 62 to 77.
6	ESCALATION: AI asks: "Did you enter your password?" → Presenter selects YES.	Risk score jumps to 92 (CRITICAL).
7	ACTIONABLE OUTPUT: ThreatIQ instantly outputs an immediate password reset protocol and exports a full Incident Report.	Executive Report generated with prioritized playbook.

Total demo time: ~4 minutes.

16. Evaluation Framework & Success Metrics

Evaluation Dimension	Target Metric Specification	Verification Methodology
Threat Classification Accuracy	≥ 85% on controlled test set	Benchmark against 100 annotated test cases (Phishing / Scams / Safe).
IOC Extraction Precision	≥ 90% precision	Automated evaluation vs ground-truth extracted domains & URLs.
Workflow Completion Rate	> 98% End-to-End Execution	Verification of full 8-step execution without orchestrator failure.
Response Safety & Grounding	100% RAG Grounded Recommendations	Zero hallucinated remediation steps verified against CISA/OWASP docs.
Dynamic Risk Recalculation Latency	< 2 seconds per user response	Timed orchestration trace.

17. Product Scope & Non-Goals

Must-Have Scope

- Multi-evidence intake (Text, URL, Email body, Screenshot OCR).
- IOC extraction & threat classification.
- 8-agent orchestration architecture + embedded Adaptive Interview and Impact Analysis modules.
- External Threat Intel lookup (VirusTotal/RDAP/WHOIS).
- Adaptive user interrogation loop.
- Dynamic risk score recalculation.
- Structured Executive Incident Report.

Explicit Non-Goals

- Full enterprise SIEM / SOC replacement.
- Antivirus endpoint replacement agent.
- Autonomous dark-web threat hunting.
- Automatic account credential resetting.
- Automated firewall IP blocking.
- Password manager or vault storage.

18. Security, Responsible AI & Product Governance

Non-Negotiable Product Safety Rules

- **API Key Isolation:** Never expose API keys or credentials in client-side code or repositories.
- **Zero Credential Storage:** Never ask users for or store actual user passwords or sensitive credentials.
- **No Guaranteed Safety Claims:** Never state "100% Safe" or guarantee absolute protection.
- **Fail Safely:** If evidence is insufficient, explicitly report "Insufficient Evidence" rather than hallucinating certainty.

19. Team Roles & Responsibilities

Role	Name	Responsibilities
Team Lead / Product Owner	[Name]	PRD authorship, scope control, demo narrative.
Agentic AI Engineer	[Name]	Orchestrator, agent prompts, shared state, risk heuristic.
Backend / Integration Engineer	[Name]	Intake pipeline, RAG store, report generation, API integration.
Frontend / UX Engineer	[Name]	Intake portal, interview UI, report viewer.
Security & Compliance Reviewer	[Name]	Responsible AI framing, safety rules, evaluation harness.

(Replace bracketed placeholders with actual team member names before submission.)

20. Development Timeline

Phase	Dates	Deliverables
Phase 1 — Research & Architecture	Week 1	PRD, agent roster, state schema, threat taxonomy.
Phase 2 — Core Agent Build	Week 2	Intake, Extraction, Threat, Correlation, Risk agents.
Phase 3 — Response & Report	Week 3	RAG store, Response Agent, Report Agent, interview loop.
Phase 4 — Integration & Testing	Week 4	End-to-end orchestration, evaluation harness, demo script.
Phase 5 — Submission & Polish	Week 5	Final PRD, video demo, report samples, references.

21. Strategic Differentiation & Conclusion

ThreatIQ vs Traditional Analyzers

Vector Dimension	Traditional Phishing Analyzers	ThreatIQ Agentic Platform
Analysis Scope	Single artifact in isolation (e.g., individual link or email)	Multi-evidence correlation (Screenshot + Message + URL + Context)
Output Type	Static binary label ("Phishing — 85% Confidence")	Full interactive investigation & contextual incident case
Risk Calculation	Static score based on initial payload analysis	Dynamic reassessment based on user interaction & exposure
Response Guidance	Generic advice ("Do not click suspicious links")	Prioritized, personalized containment playbook (Immediate/ Next/ Monitor)

How ThreatIQ Differs from Existing Tools

- **PhishTank / VirusTotal:** These are reputation databases. They answer "is this known-bad?" ThreatIQ answers "what happened to me, and what do I do now?"
- **ChatGPT / Generic LLMs:** These generate plausible text but lack structured incident state, dynamic risk scoring, and grounded containment playbooks. ThreatIQ is an investigation environment, not a chat prompt.
- **Enterprise SOAR / SIEM:** These are built for SOC analysts and require technical expertise. ThreatIQ is built for non-technical users and SMB operators.

ThreatIQ — From Suspicion to Action

Detection tells you something may be wrong.

Investigation tells you what might have happened.

Response tells you what to do next.

ThreatIQ seamlessly connects all three into a single autonomous AI platform.

22. References

- CISA — Incident Response Playbooks: <https://www.cisa.gov/>
- OWASP — Credential Management Cheat Sheet: <https://owasp.org/>
- NIST SP 800-61 — Computer Security Incident Handling Guide: <https://csrc.nist.gov/>

23. Glossary

Term	Definition
IOC	Indicator of Compromise — a piece of forensic data suggesting a breach.
RDAP	Registration Data Access Protocol — successor to WHOIS for domain registration data.
WHOIS	Query protocol for domain registration information.
BEC	Business Email Compromise — a scam where attackers impersonate executives to initiate fraud.
MFA	Multi-Factor Authentication — a second verification step beyond a password.
RAG	Retrieval-Augmented Generation — grounding LLM output in retrieved authoritative documents.
SOAR	Security Orchestration, Automation, and Response — enterprise security tooling.
SIEM	Security Information and Event Management — enterprise log correlation platform.
SMB	Small and Medium-sized Business.
TLD	Top-Level Domain — the final segment of a domain name (e.g., .com, .xyz).
SSO	Single Sign-On — one login across multiple services.
OCR	Optical Character Recognition — extracting text from images.